



VULNERABILITY ASSESSMENT REPORT

>> OWASP Juice Shopping

Presentation By: KOSANA AKSHAYA

Future Interns - Cyber Security Internship



INTRODUCTION

This report presents a basic vulnerability assessment of the OWASP Juice Shop web application. The assessment was conducted using Nmap, SecurityHeaders.com, and Wappalyzer.



SCOPE OF ASSESSMENT

Target website:

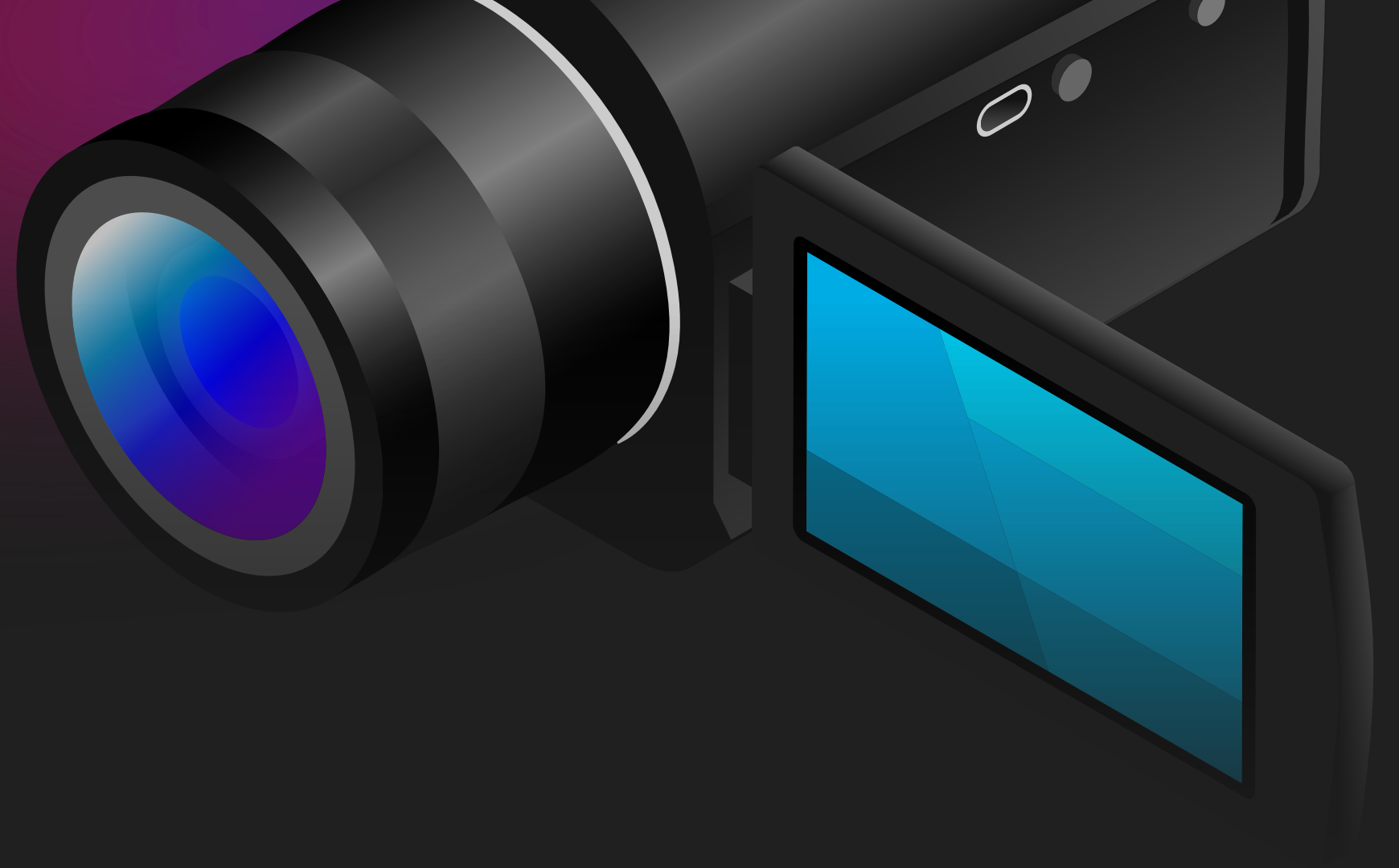
OWASP Juice Shop

Assessment Type:

Read-Only Vulnerability Assessment

Tools Used:

- Nmap 7.99
- SecurityHeaders.com
- Wappalyzer





NMAP SCAN RESULTS

- *Host is reachable and active.*
 - *Port 80 (HTTP) is open.*
 - *Port 443 (HTTPS) is open.*
- *998 TCP ports are filtered.*

```
Command Prompt
Microsoft Windows [Version 10.0.26200.8457]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Veeravalli Lalitha>nmap juice-shop.herokuapp.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-23 12:10 +0530
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.61 seconds

C:\Users\Veeravalli Lalitha>nmap -Pn juice-shop.herokuapp.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-23 12:15 +0530
Nmap scan report for juice-shop.herokuapp.com (54.220.192.176)
Host is up (0.40s latency).
Other addresses for juice-shop.herokuapp.com (not scanned): 54.73.53.134 46.137.15.86 64:ff9b::2e89:f56
rDNS record for 54.220.192.176: ec2-54-220-192-176.eu-west-1.compute.amazonaws.com
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 33.57 seconds

C:\Users\Veeravalli Lalitha>
```

Risk Level: Low

Recommendations:

- *Continue enforcing firewall rules.*
 - *Redirect HTTP traffic to HTTPS.*
- *Monitor exposed services regularly.*



Security Headers Analysis



RESULT:
F Grade



MISSING HEADERS:

- HSTS
- CSP
- X-Frame-Options
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy



RISK LEVEL:
Medium



[Home](#) [About](#) [API](#)

Scan your site now

Scan

☐ Hide results ☒ Follow redirects

Security Report Summary



Site: <https://juice-shop.herokuapp.com/>

IP Address: 46.137.15.86

Report Time: 23 May 2026 06:55:52 UTC

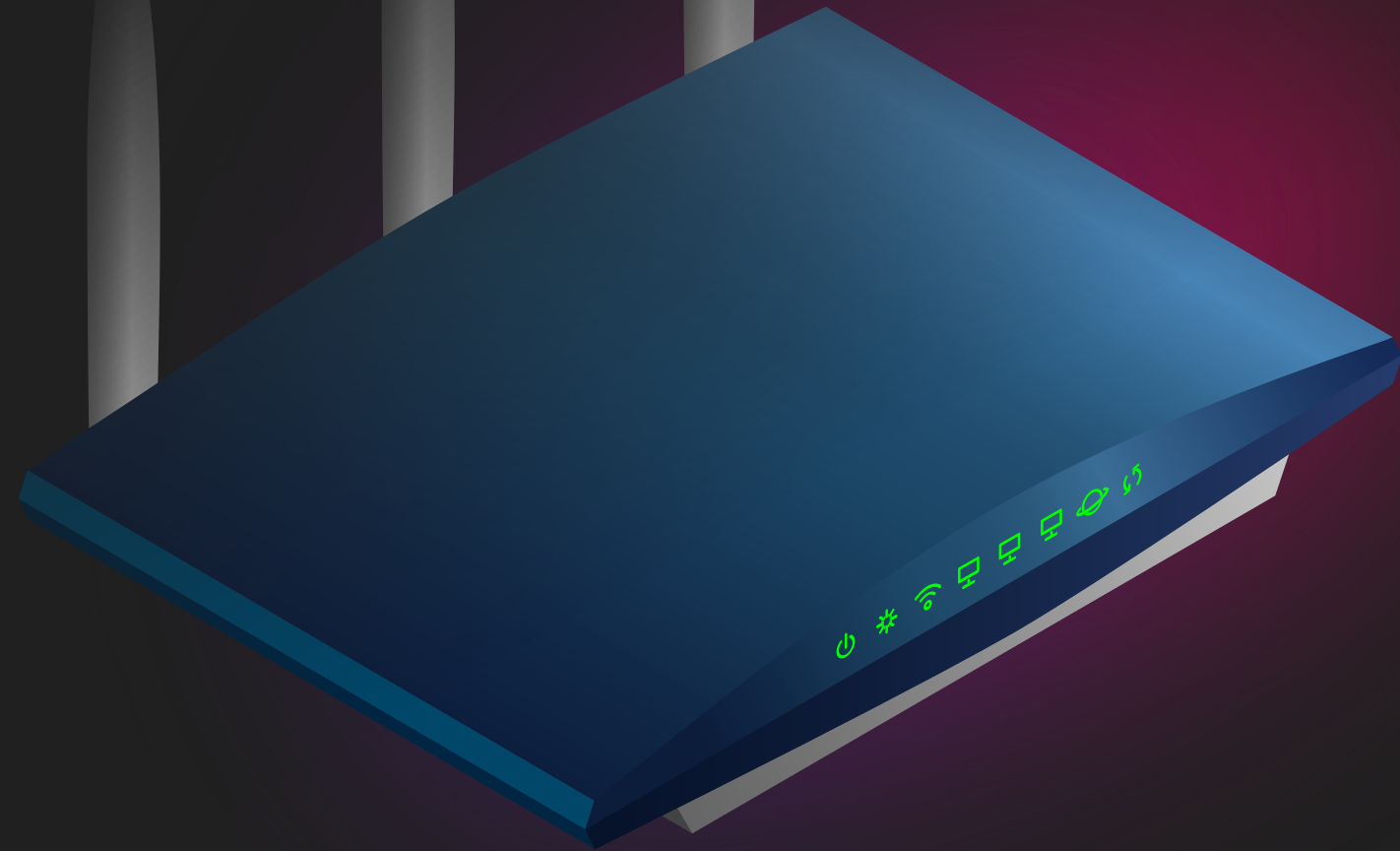
Headers:

✖ Strict-Transport-Security ✖ Content-Security-Policy ✖ X-Frame-Options ✖ X-Content-Type-Options
✖ Referrer-Policy ✖ Permissions-Policy

Advanced:

Ouch, you should work on your security posture immediately:

[Start Now](#)



SECURITY IMPACT



- * Missing CSP may increase XSS risks.*
- * Missing X-Frame-Options may allow clickjacking.*
- * Missing HSTS weakens HTTPS enforcement.*
- * Missing Referrer-Policy may expose URL information.*





TECHNOLOGY ANALYSIS



WIDGETS:
SoundCloud

FONT SCRIPTS:
Font Awesome



CACHING:
Varnish 1.1

CDN:
Fastly

CDN:
Cloudflare



STORAGE:
Amazon S3

JAVASCRIPT:
jQuery 3.7.1

PAAS:
AWS



HOSTING:
GitHub Pages

owasp.org/www-project-juice-shop/?utm_source=chatgpt.com

Please support the OWASP mission to improve software security through open source projects.

OWASP

PROJECTS CHAPTERS EVENTS ABOUT

OWASP Juice Shop

Main Overview News Challenges Learning CTF Ecosystem Supporters

For the latest information about OWASP Juice Shop visit <https://owasp-juice.shop>

owasp flagship project release v20.0.0 GitHub 13k Follow

OWASP Juice Shop is probably the most modern and sophisticated insecure web application! It can be used in security trainings, awareness demos, CTFs and as a guinea pig for security tools! Juice Shop encompasses vulnerabilities from the entire OWASP Top Ten along with many other security flaws found in real-world applications!

Slideshow

Description

OWASP Juice Shop is a modern and sophisticated insecure web application. It is designed to be used in security trainings, awareness demos, CTFs and as a guinea pig for security tools. Juice Shop encompasses vulnerabilities from the entire OWASP Top Ten along with many other security flaws found in real-world applications!

Wappalizer

TECHNOLOGIES MORE INFO Export

Widgets

- SoundCloud

Font scripts

- Font Awesome

Miscellaneous

- Open Graph

Caching

- Varnish 1.1

CDN

- Fastly
- Cloudflare
- Amazon S3

JavaScript libraries

- jQuery 3.7.1

PaaS

- Amazon Web Services
- GitHub Pages

Something wrong or missing?

Tool

Audience

- Builder
- Breaker
- Defender



RISK ASSESSMENT SUMMARY

— Open HTTP Port (80) - Low



— Open HTTPS Port (443) - Low

— Missing Security Headers - Medium

— Technology Fingerprinting - Low





RECOMMENDATIONS

CONTENT:

1. Configure Content-Security-Policy.
2. Enable HSTS.
3. Add X-Frame-Options.
4. Add X-Content-Type-Options.
5. Configure Referrer-Policy.
6. Perform regular security audits.
7. Keep technologies updated.





CONCLUSION

- The assessment identified open web service ports and several missing HTTP security headers. Firewall controls are in place, but security can be improved through proper header implementation and regular security reviews.





NMAP

```
Command Prompt
Microsoft Windows [Version 10.0.26200.8457]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Veeravalli Lalitha>nmap juice-shop.herokuapp.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-23 12:10 +0530
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.61 seconds

C:\Users\Veeravalli Lalitha>nmap -Pn juice-shop.herokuapp.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-23 12:15 +0530
Nmap scan report for juice-shop.herokuapp.com (54.220.192.176)
Host is up (0.40s latency).
Other addresses for juice-shop.herokuapp.com (not scanned): 54.73.53.134 46.137.15.86 64:ff9b::2e89:f56 64:ff9b::36dc:c0b0 64:ff9b::3649:3586
rDNS record for 54.220.192.176: ec2-54-220-192-176.eu-west-1.compute.amazonaws.com
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 33.57 seconds

C:\Users\Veeravalli Lalitha>
```

WAPPALYZER

OWASP

OWASP Juice Shop

Main Overview News Challenges Learning CTF Ecosystem Supporters

For the latest information about OWASP Juice Shop visit <https://owasp-juice-shop.com>

OWASP Juice Shop is probably the most modern and sophisticated insecure web application! It can be used in security trainings, awareness demos, CTFs and as a guinea pig for security tools! Juice Shop encompasses vulnerabilities from the entire OWASP Top Ten along with many other security flaws found in real-world applications!

Slideshow

Description

Wappalyzer

TECHNOLOGIES MORE INFO Export

Widgets

Font scripts

Miscellaneous

Caching

CDN

JavaScript libraries

PaaS

Tool

Audience

Builder

Breaker

Defender

Donate

Join

EVIDENCE

SECURITYHEADERS

Security Headers

by snyk

Scan your site now

https://juice-shop.herokuapp.com

Scan

Hide results

Follow redirects

Security Report Summary

F

Site:

IP Address:

Report Time:

Headers:

Advanced:

https://juice-shop.herokuapp.com/

46.137.15.86

23 May 2026 06:55:52 UTC

Strict-Transport-Security

Content-Security-Policy

X-Frame-Options

X-Content-Type-Options

Referrer-Policy

Permissions-Policy

Ouch, you should work on your security posture immediately:

Start Now